Mapping Remaining OWASP ASVS 5.0 Requirements

Objective

Replace the prior chapter-only mapping with a version-pinned, requirement-level control matrix. ASVS 5.0.0 has 345 requirements across 17 chapters. Do not derive IDs/text from old 4.0.3 documents, summaries, or an LLM; obtain the official 5.0.0 release artifact and preserve it with a hash and retrieval date.

Procedure

1. Freeze scope: commit, apps/services, environments, data classes, API types, integrations, and planned ASVS level. Record exclusions and rationale.
2. Acquire the official ASVS 5.0.0 source from OWASP, retain the release/tag reference and SHA-256 of the downloaded source. Capture official requirement ID, title/text, level, chapter, and applicability fields in a controlled CSV.
3. Import requirements into `asvs-5-requirement-matrix.csv` with columns: `asvs_version,asvs_id,chapter,requirement_text,level,applicable,applicability_rationale,asset_or_feature,control_id,implementation_ref,test_id,test_type,evidence_uri,status,owner,reviewer,last_verified,next_review,exception_id,notes`.
4. Decide applicability one requirement at a time. “Not using WebRTC,” for example, can make V17 requirements N/A, but only after architecture confirmation. OAuth/OIDC, GraphQL, WebSockets, uploads, payments, and AI require feature-based scoping; do not mark whole chapters N/A casually.
5. Link each applicable ASVS requirement to one or more Semester controls, implementation references, and test cases. One control can satisfy multiple requirements, but each requirement needs its own evidence/decision record.
6. Test independently: source/configuration inspection, automated test, manual behavior test, and operational evidence where relevant. Record exact environment, commit/deploy, test identity/role, expected/actual result, artifact hash, and tester.
7. Have security review PASS, FAIL, N/A, and exception decisions. Exceptions need risk owner, compensating control, expiry, and retest date. A merged ticket does not prove a requirement is met.
8. Produce chapter rollups only from rows: applicable PASS / applicable total; report FAIL, unverified, N/A, and exception counts separately. Never call a partially scoped spreadsheet “ASVS compliant.”

Semester priority map

ASVS 5 chapter	First implementation work
V8 Authorization	Table/view/function/storage/realtime inventory; RLS and direct RPC cross-user/cross-tenant tests
V6/V7/V9/V10	Auth, session/revocation, JWT and any OIDC/OAuth integration tests
V14	Student data classification, exports, retention, backups, logs
V4	API route inventory, schemas, rate limits, webhooks, authorization matrix
V1/V2/V3	Input schemas, safe React DOM usage, rich content, browser headers/origins
V5	File paths, private object policies, signed URL/revocation limits
V13/V15/V16	CI/deploy/config drift, dependencies, secure code review, audit events/errors
V11/V12	Key lifecycle, TLS, webhook/integration transport trust
V17	Mark N/A only after confirming WebRTC is absent

Quality gate

A requirement may be PASS only when: it is applicable; the implementation reference is current; a reproducible test verifies expected behavior in scope; evidence is retained; and a qualified reviewer accepts it. Otherwise use NOT_VERIFIED, FAIL, N/A, or ACCEPTED_EXCEPTION. Re-evaluate when the system, dependencies, architecture, environment, or ASVS version changes.